Data: 23 ottobre 2026
Studente: Monyrath Mosetti

Report laboratorio – U1S3L5
Creazione di una policy firewall con pfSense

Obiettivo

Creare una regola firewall che blocchi l'accesso alla DVWA (su Metasploitable 2) dalla macchina Kali Linux e ne impedisca di conseguenza lo scan. Un requisito fondamentale dell'esercizio è che le macchine Kali e Metasploitable 2 siano su reti diverse, potete aggiungere una nuova interfaccia di rete a Pfsense in modo tale da gestire una ulteriore rete.

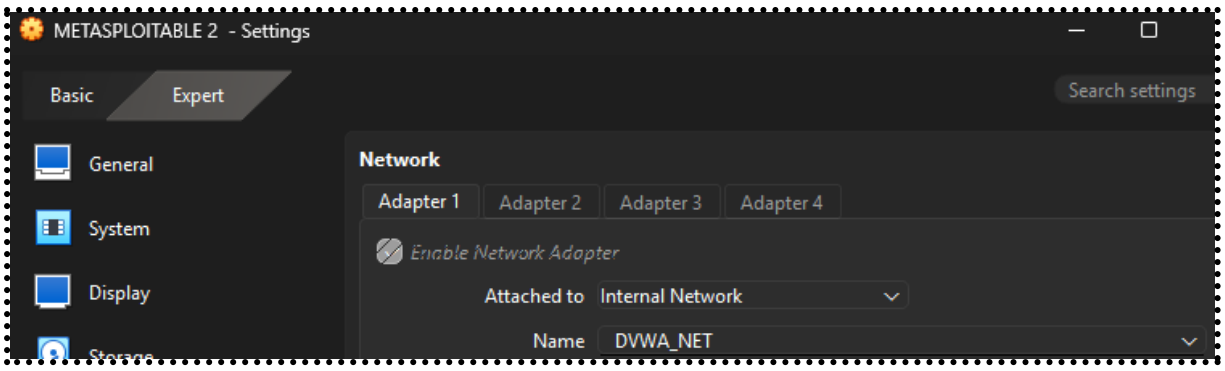
Punto 1 – Preparazione e configurazione delle reti

Il laboratorio è stato realizzato in VirtualBox utilizzando tre macchine virtuali:

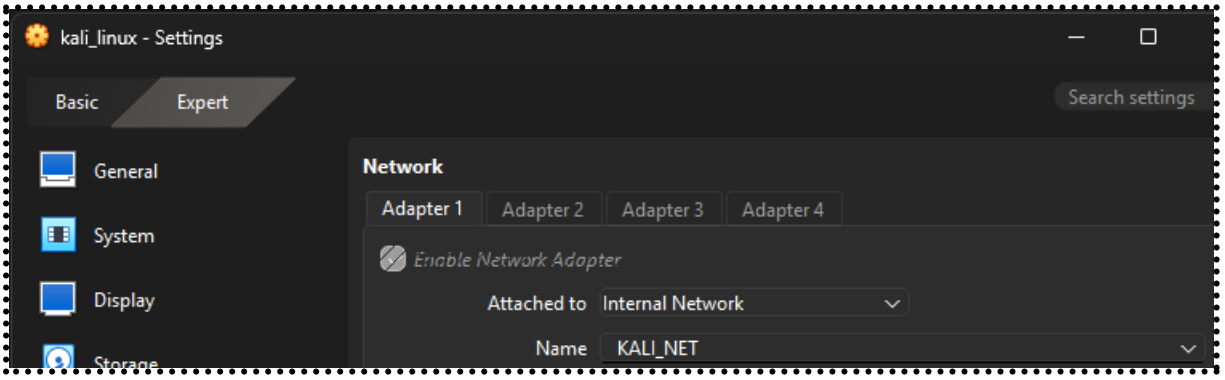
- **Kali Linux**, utilizzata per effettuare i test.
- **pfSense**, utilizzata come firewall e gateway.
- **Metasploitable 2**, sulla quale è presente DVWA.

configurazione schede di rete del VM su OVBM:

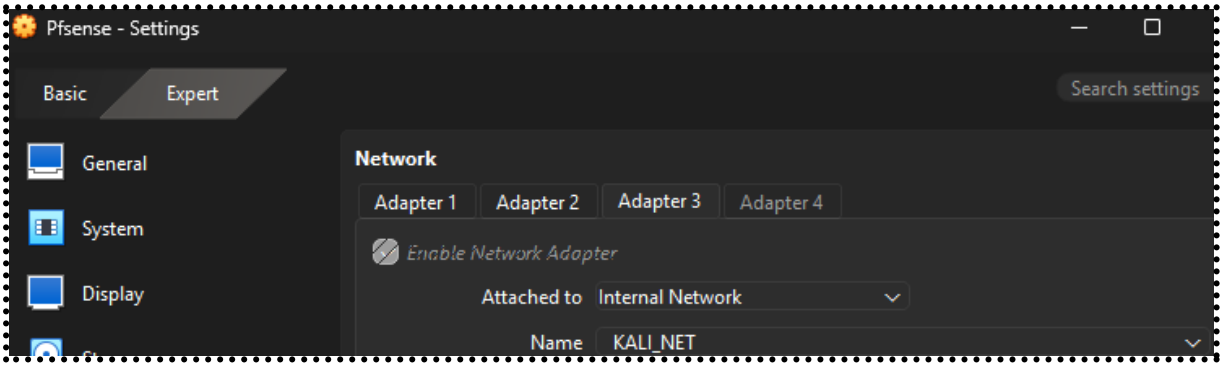
Metasploitable 2:



Kali Linux:



pfSense OPT1:



pfSense LAN:

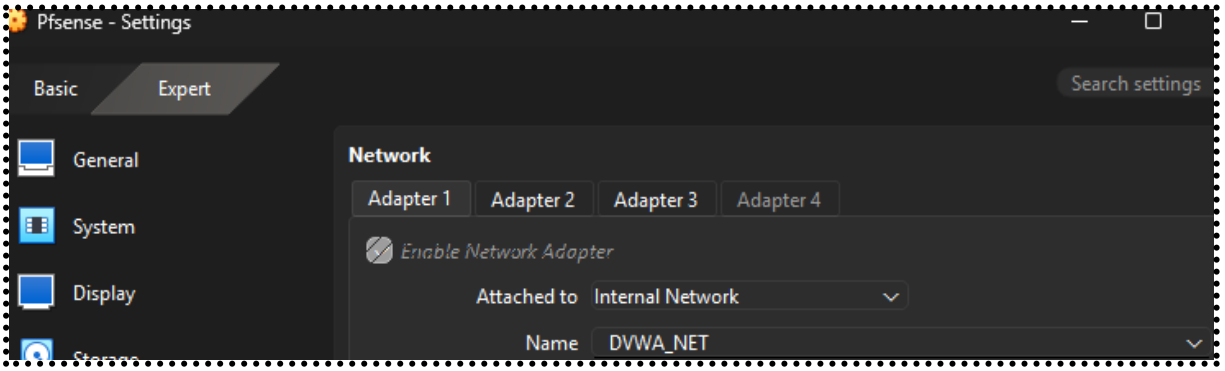
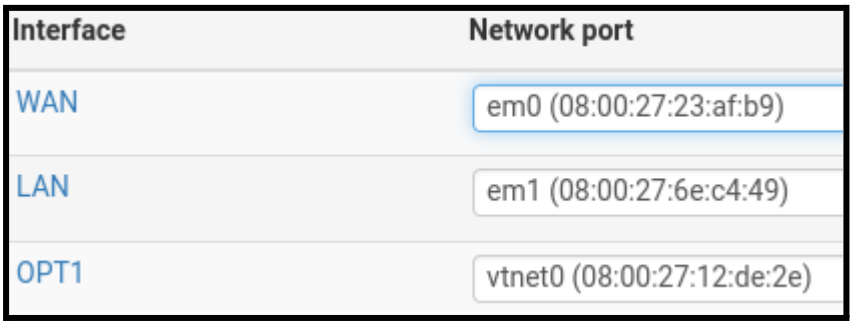


Tabella configurazione delle due reti interne separate:

Macchina/interfaccia	Rete	Indirizzo IP	Gateway
Kali Linux	KALI_NET	192.168.50.10/24	192.168.50.1
pfSense LAN	KALI_NET	192.168.50.1/24	—
pfSense OPT1	DVWA_NET	192.168.60.1/24	—
Metasploitable 2	DVWA_NET	192.168.60.10/24	192.168.60.1

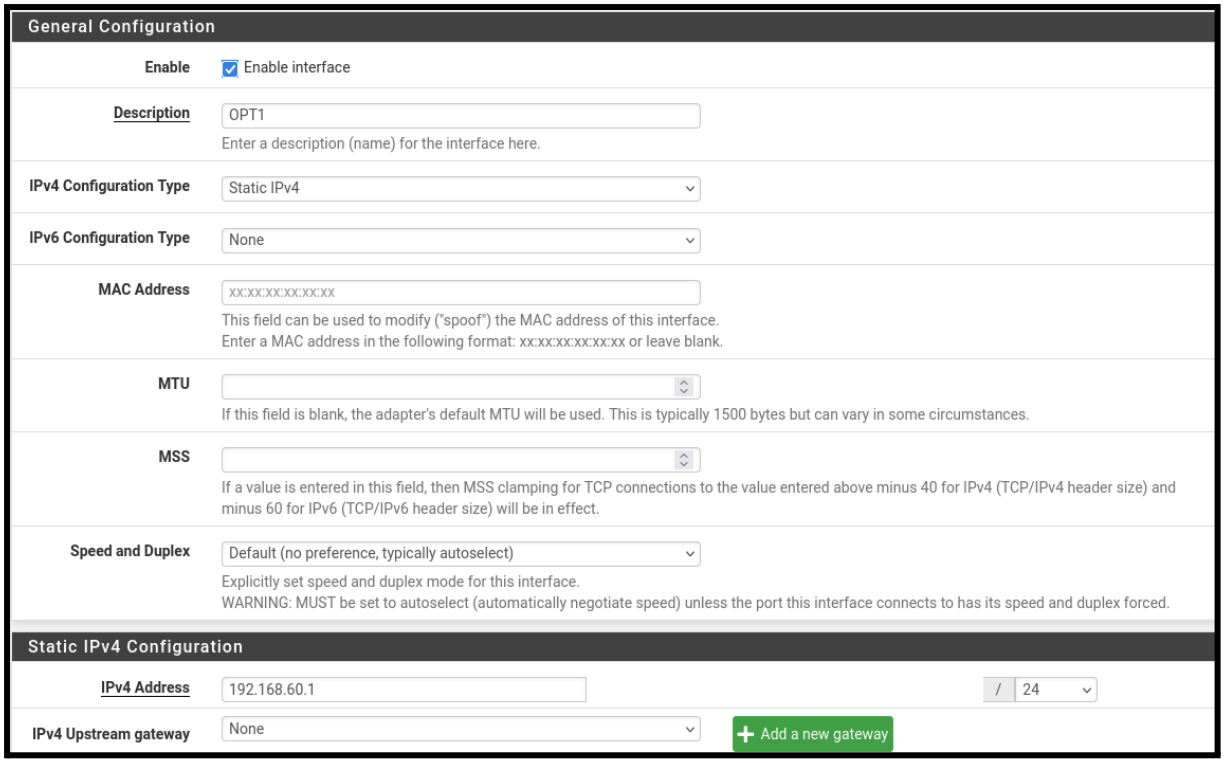
Si configura la WAN di pfSense in modalità NAT su VirtualBox per consentirne l'accesso alla rete esterna.

Successivamente, tramite la Web GUI, nella sezione **Interfaces → Assignments**, si verificano le assegnazioni delle interfacce per controllare il corretto collegamento di pfSense alle due reti interne denominate *KALI_NET* e *DVWA_NET*.



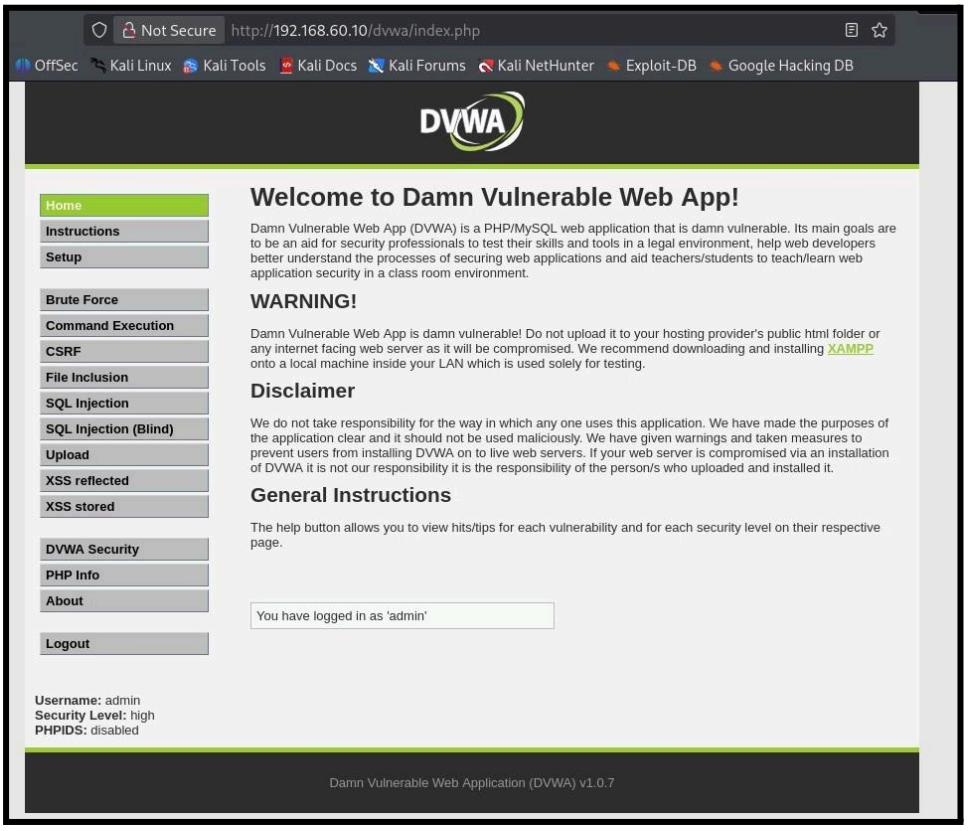
Nella configurazione di *OPT1* sono stati usati i seguenti parametri:

- **Enable interface:** abilitato
- **IPv4 Configuration Type:** Static IPv4
- **IPv4 Address:** 192.168.60.1/24
- **IPv4 Upstream gateway:** None



Prima di applicare il blocco è stato verificato l'accesso da Kali al: http://192.168.60.10/dvwa/

La pagina è risultata raggiungibile ed è stato effettuato il login.



Punto 2 – Creazione della regola firewall

Dalla Web GUI di pfSense è stata aperta la sezione **Firewall → Rules → LAN**.

È stata scelta la LAN perché il traffico proveniente da Kali entra in pfSense attraverso questa interfaccia.

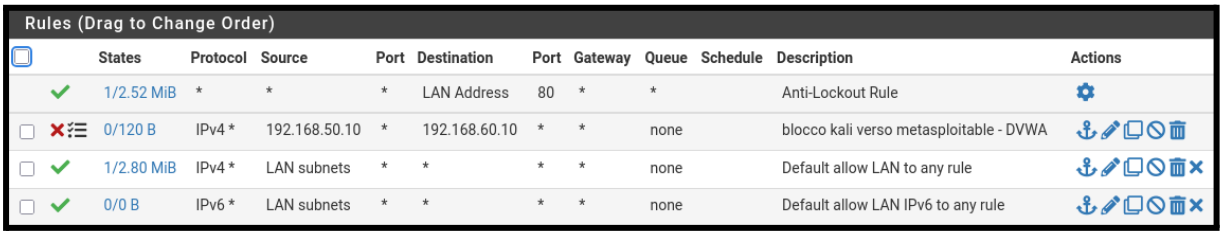
La regola è stata configurata come segue:

Campo	Valore	Funzione
Action	Block	Scarta i pacchetti senza rispondere
Interface	LAN	Controlla il traffico in ingresso da KALI_NET
Address Family	IPv4	Applica la regola al traffico IPv4
Protocol	Any	Comprende tutti i protocolli IPv4
Source	192.168.50.10	Identifica Kali
Destination	192.168.60.10	Identifica Metasploitable 2
Log	Abilitato	Registra i pacchetti bloccati

N.B. **Protocol** → **Any**, il blocco comprende tutti i protocolli IPv4 e tutte le porte da Kali verso Metasploitable 2, inclusa la porta HTTP 80 utilizzata da *DVWA*.

La regola è stata posizionata prima di **"Default allow LAN to any rule"**, per darle precedenza sulla regola di autorizzazione.

La configurazione è stata salvata e attivata tramite **Apply Changes** (in alto a destra appena si salvano le modifiche).



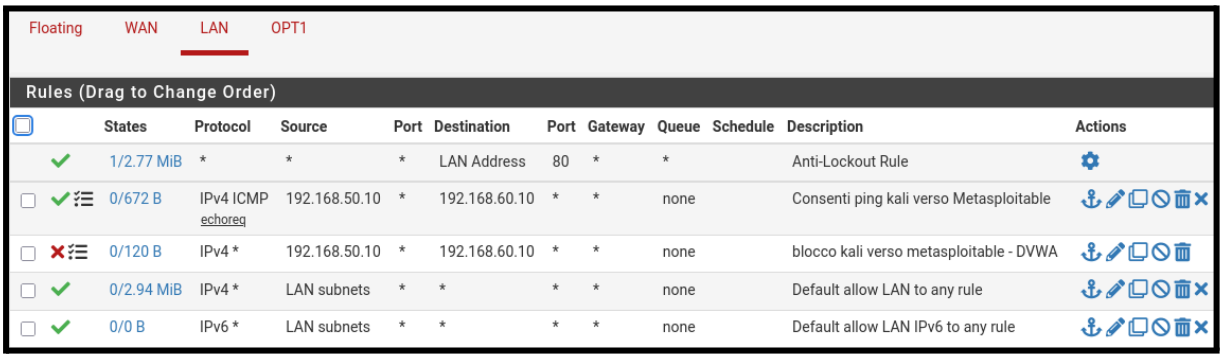
Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✓	1/2.52 MiB	*	*	*	LAN Address	80	*	*		Anti-Lockout Rule	⚙
✗ ☰	0/120 B	IPv4 *	192.168.50.10	*	192.168.60.10	*	*	none		blocco kali verso metasploitable - DVWA	⚓ ✎ ⧉ ⊘ 🗑
✓	1/2.80 MiB	IPv4 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	⚓ ✎ ⧉ ⊘ 🗑 ✗
✓	0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN IPv6 to any rule	⚓ ✎ ⧉ ⊘ 🗑 ✗

Punto 3 - Ping tra kali e Metasploitable 2

Creata la regola "**blocco kali verso Metasploitable 2 - DVWA**" devo permettere il ping tra le due VMs mantenendo il blocco degli altri protocolli grazie alla creazione di altre due regole di autorizzazione *ICMP* (consente il ping mantenendo la raggiungibilità):

1. **LAN:** da Kali (192.168.50.10) verso Metasploitable 2 (192.168.60.10), con sottotipo **Echo request**. La regola è stata posizionata sopra quella di blocco.



Floating WAN LAN OPT1

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✓	1/2.77 MiB	*	*	*	LAN Address	80	*	*		Anti-Lockout Rule	⚙
✓ ☰	0/672 B	IPv4 ICMP echoreq	192.168.50.10	*	192.168.60.10	*	*	none		Consenti ping kali verso Metasploitable	⚓ ✎ ⧉ ⊘ 🗑 ✗
✗ ☰	0/120 B	IPv4 *	192.168.50.10	*	192.168.60.10	*	*	none		blocco kali verso metasploitable - DVWA	⚓ ✎ ⧉ ⊘ 🗑
✓	0/2.94 MiB	IPv4 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	⚓ ✎ ⧉ ⊘ 🗑 ✗
✓	0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN IPv6 to any rule	⚓ ✎ ⧉ ⊘ 🗑 ✗

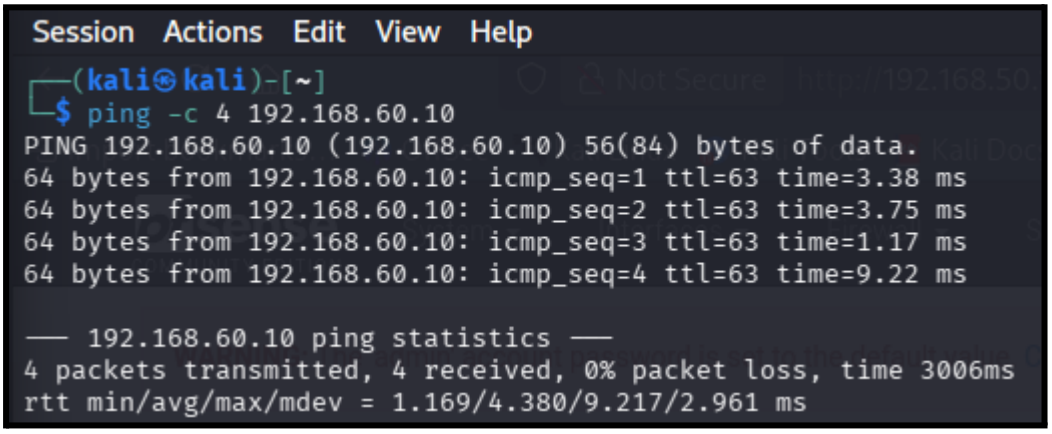
2. **OPT1:** da Metasploitable 2 (192.168.60.10) verso **Any**, con sottotipo **Echo request**, per consentire il ping verso Kali e gli indirizzi di pfSense.



Entrambe le regole sono state salvate e applicate e sono state abilitate le registrazioni nei log.

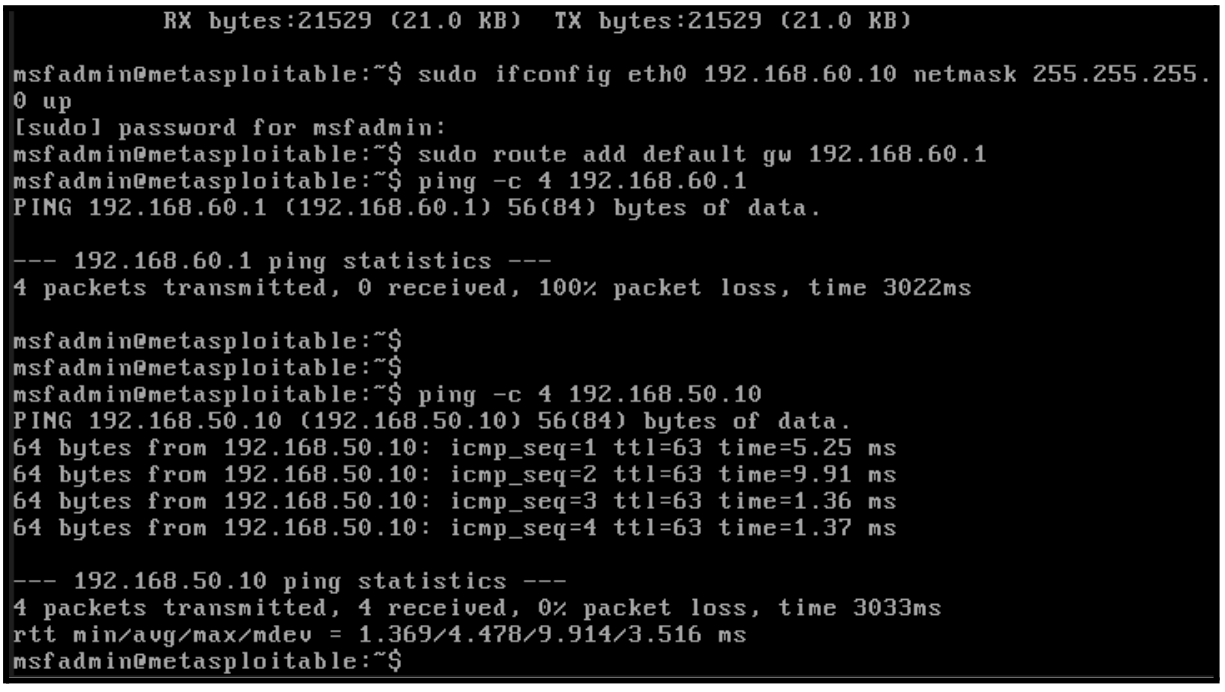
Dal terminale di Kali è stato eseguito:

`ping -c 4` (per comodita) `192.168.60.10`



viceversa dal terminale di Metasploitable 2:

`ping -c 4 192.168.50.10`



I test hanno ricevuto risposte, confermando la comunicazione ICMP da Kali verso Metasploitable 2 e viceversa.

Punto 4 – Verifica dell'accesso e della scansione

Dopo l'attivazione della regola "**blocco kali verso Metasploitable 2 - DVWA**" sono state eseguite due verifiche dal terminale di Kali.

Test dell'accesso a DVWA

È stato eseguito il comando:

```
curl --connect-timeout 5 (imposta attesa massima di 5 secondi per stabilire la connessione)
http://192.168.60.10/dvwa/
```

Il risultato è stato:

```
Connection timed out after 5004 milliseconds
```

La connessione a DVWA è scaduta dopo circa 5 secondi, in linea con il blocco confermato dai log di pfSense.

Test della scansione della porta web

È stato eseguito il comando:

```
nmap -Pn (esegue il test senza verifica ping) -sT (prova a stabilire connessione TCP) -p 80 (controlla
soltanto la porta 80) --reason (motivo del risultato) 192.168.60.10 (identifica Metasploitable 2)
```

Il risultato è stato:

```
80/tcp filtered http – no-response
```

La scansione della porta 80 ha restituito lo stato "**filtered**" per assenza di risposta; i log di pfSense hanno confermato il blocco dei tentativi.

```
┌──(kali㉿kali)-[~]
└─$ curl --connect-timeout 5 http://192.168.60.10/dvwa/
curl: (28) Connection timed out after 5002 milliseconds

┌──(kali㉿kali)-[~]
└─$ nmap -Pn -sT -p 80 --reason 192.168.60.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-23 06:36 -0400
Nmap scan report for 192.168.60.10
Host is up, received user-set.

PORT   STATE    SERVICE REASON
80/tcp filtered http    no-response

Nmap done: 1 IP address (1 host up) scanned in 2.52 seconds

┌──(kali㉿kali)-[~]
└─$
```

N.B. la scansione può essere fatta sulle **1024 porte** più comuni per un controllo preliminare oppure estesa a tutte le **65.535 porte TCP** per ottenere un'analisi più completa.

es.

1. `nmap -Pn -sT -p 1-1024  --reason 192.168.60.10`
2. `nmap -Pn -sT -p-  --reason 192.168.60.10`

Punto 5 – Controllo dei log

Per verificare l'intervento della regola si possono controllare i Log tramite i passaggi seguenti;

Status → System Logs → Firewall.

✕	Oct 23 12:16:18	OPT1	Default deny rule IPv4 (1000000103)	0.0.0.0:68	255.255.255.255:67	UDP
✕	Oct 23 12:16:39	OPT1	Default deny rule IPv4 (1000000103)	0.0.0.0:68	255.255.255.255:67	UDP
✕	Oct 23 12:16:45	LAN	blocco kali verso metasploitable - DVWA (1792745601)	192.168.50.10:52782	192.168.60.10:80	TCP:S
✕	Oct 23 12:16:46	LAN	blocco kali verso metasploitable - DVWA (1792745601)	192.168.50.10:52798	192.168.60.10:80	TCP:S

Le due righe nell'immagine sopra confermano che la regola **“blocco kali verso Metasploitable 2 - DVWA”** ha bloccato dei tentativi di connessione da Kali (192.168.50.10) verso la porta web 80 di Metasploitable 2 (192.168.60.10).

Conclusione

L’attività ha permesso di configurare due reti separate e controllare il traffico tra Kali e Metasploitable 2 tramite pfSense.

Prima dell’attivazione della regola, DVWA era accessibile da Kali.

Dopo il blocco, la connessione HTTP è stata bloccata e la scansione della porta 80 ci ha dato il risultato “filtered”; successivamente i log di pfSense ci hanno confermato il funzionamento della regola appena inserita.

La regola che creava il blocco tra kali e Metasploitable 2 agiva ad ampio raggio e impediva il ping tra le due VMs, per questo è stato necessario creare altre due regole per permetterlo.

Si potrebbe cambiare anche la prima regola da me inserita sulla LAN e permettere lo scansionamento di altre porte e limitare quello della porta 80.

Ho optato per il **PROTOCOL** “*ANY*” e non “*TCP*” poiché volevo fare un blocco più ampio e poter aggiungere più regole per capirne meglio il funzionamento.